Journal of Intelligent Decision Making and Information Science

www.jidmis.org

eISSN: 3079-0875



Designing a Scalable and Adaptive Cyber Incident Response (DACIR) Framework for SMEs

Alireza Nik Aein Koupaei[1] , Ilker Demirkol[2]

1,2 Department of Mining, Industrial and ICT Engineering, Universitat Politècnica de Catalunya - Barcelona Tech (UPC)

ARTICLE INFO

Article history:

Received 08 April 2026

Received in revised form 10 May 2026

Accepted 24 May 2026

Keywords: Incident Response, SMEs, Optimized Framework, Risk, Cyber Attacks .

ABSTRACT

Small and medium-sized enterprises (SMEs), due to resource constraints, lack optimal decision-making mechanisms to respond to cyber incidents. Common frameworks model the process as linear cycles and lack explicit decision-making under uncertainty. This paper presents an optimized framework as a partially observable Markov decision process (POMDP), in which the system's true state is not fully observable and the decision-maker must act based on a belief distribution. Risk is dynamically estimated on the asset dependency graph, and action selection is performed by minimizing expected loss, cost, downtime, and uncertainty penalty. The proposed framework (DACIR) provides lightweight, executable orchestration for SMEs using micro-playbooks and updates policy parameters through post-event learning. Simulation-based evaluation shows that the proposed method, compared to static procedures, achieves significant improvement in metrics such as MTTR, business loss, and regret.

1. Introduction

The rise in targeted attacks has turned SMEs into high-reward targets for attackers. In practice, small IT teams must balance response speed, business continuity, and cost. While, comprehensive common frameworks are resource-blind and decision-agnostic. This paper redefines incident response as a stochastic control problem under incomplete observation so that action selection is made explicitly and optimally. (*Almara et al, 2026*). To clarify these challenges, the biggest difference between current cyberattacks and past ones is their increasing complexity and "personalization." Thanks to artificial intelligence (AI), hackers can create personalized attack scenarios for each individual, from the content of emails and messages to their approaches, tailored to a person's job position, interests, and even their communication style (*Casaril et al. 2026*). Malware is not only evolving in its fraudulent nature but has also undergone significant changes. New types of malware no longer operate according to fixed scenarios; instead, they can alter their behavior or add new functions after infiltrating systems. This makes detection and prevention much more difficult than before (*Azeroual et al, 2026*). From a technical perspective, there has also been a warning about the increase in supply chain attacks, where hackers do not attack businesses directly but instead target partners, software providers, or intermediary service providers (*Cordey, Sean, 2023*). This is

particularly dangerous for small businesses, which often rely on external platforms and services. In fact, small and medium-sized enterprises (SMEs) are becoming the most targeted. Statistics shared at the seminar showed that over 50% of current cyberattacks target this group of businesses, while most data encryption attacks occur in businesses with fewer than 500 employees.

In today's digital age, small and medium-sized enterprises (SMEs), as the backbone of the global economy, are more vulnerable to cyber threats than ever before. Unlike large organizations that have extensive infrastructure and dedicated security teams, small businesses often grapple with the challenge of limited resources. In this context, a cyber incident for these enterprises is not just a technical challenge but a critical threat to their economic survival (*Muhammad et al, 2025*). The central question is: how can one best and most quickly respond to cyber incidents when financial and human resources are limited? Traditional incident response approaches, which often focus on "maximum security," are sometimes costly and inefficient for the agile and constrained environments of small businesses (*Schlette et al, 2025*).

This research, aimed at bridging this gap, seeks to develop an "optimization model" and a "formulation framework" for cyber incident management. The goal of this approach is to provide a solution where incident response is not based on guesswork, but on an intelligent decision-making model; a model that can establish a logical balance between "response costs," "business continuity," and "mitigating the attack's destructive effects." By implementing this framework, small business managers will be able to make decisions that minimize the risk of financial and reputational damage and optimize the path to recovery, even with limited resources (*Gonzaga et al, 2026*). The main problem addressed in this research is that incident response in SMEs is not a linear process, but rather a dynamic decision-making problem under resource constraints, uncertainty, and system dependencies. Therefore, there is a need for a framework that can:

- dynamically model risk,
- incorporate business impacts into decision-making,
- and optimize response actions.

In this regard, this paper introduces the DACIR framework, which models incident response as a trade-off problem between risk and utility under operational constraints

2. Literature Review

Despite increased investment in information security, the growing trend of cyber incidents and the heavy financial losses they cause continues unabated (*Nelson et al, 2025*). Organizations primarily use traditional, linear incident response (IR) frameworks—including the stages of prevention, detection, containment, eradication, and learning to counter these threats (*He, Y, et al, 2022*). Given the increasing complexity of cyberattacks and the ineffectiveness of traditional methods, it emphasizes the need for "agility" in the Incident Response (IR) process (). By analyzing data from interviews with 20 experts from the perspective of the "Situational Resource-Based View," we show how "real-time analytics" capabilities (RTA) including complex event processing, decision automation, and continuous data analytics leads to the activation of agile characteristics (speed,

flexibility, and innovation) in incident response and ultimately enhances an organization's cybersecurity performance (*Naseer et al, 2021*). This research presents a lightweight, resource-aware incident response framework for small and medium-sized enterprises (SMEs) that, by simplifying complex standard cycles (such as NIST and IEC) into four operational stages, addresses the budgetary and personnel constraints of these organizations. This model, which focuses on simple procedures and usability for non-technical staff, has been validated through consultations with more than ten European companies and has demonstrated a significant improvement in the clarity and feasibility of implementing security procedures (*Almaini, et al, 2026*). Most incident response frameworks assume assets are independent and do not explicitly factor service dependencies and attack propagation across the network into decision-making (*Junior et al., 2023*). The study Cyber Security Incident Handling, Warning and Response System for the European Critical Information Infrastructures points out that modern cyber environments are highly interconnected, and response must take dependencies and propagation dynamics into account (*Papastergiou et al., 2020*). Additionally, the paper “A Model-Based Framework for Developing Security-Safety Incident Response Plans” states that standard frameworks like NIST and ISO lack an integrated mechanism for modeling system interdependencies and cross-domain coordination (*Gnanasekaran, et al., 2025*). The study “How can organizations develop situation awareness for incident response” also highlights the importance of situation awareness and understanding context and business dependencies for effective response (*Ahmad, et al., 2021*). Common frameworks typically focus on defining phases and procedures and make less use of formal decision-making models such as MDP/POMDP or optimization-based policy. The study “Real-time Analytics, Incident Response Process Agility, and Enterprise Cybersecurity Performance,” although it introduces the concept of decision automation, still does not provide a mathematical decision policy or formalized action selection (*Naseer, et al., 2021*). The article “Patchwork of Confusion: The Cybersecurity Coordination Problem” also points to the lack of coordinated, formal coordination mechanisms in cyber response (*Chaudhary, et al., 2018*). In the study “Incident-Centered Information Security: Managing a Strategic Balance Between Prevention and Response,” the concept of a strategic balance between prevention and response is introduced, but the process of selecting actions remains heuristic and informal (*Baskerville, et al., 2014*). Even newer frameworks like Employing LLMs for Incident Response Planning and Review focus more on generating playbooks rather than formal policy optimization (*Hays, et al., 2024*).

Existing literature primarily:

- Views the process as linear;

- Does not explicitly model resource constraints and the cost of delay;

- Does not account for asset dependencies and blast radius;

- Lacks a formal decision-making policy.

Gap: the absence of a model that optimally formulates action selection under uncertainty, cost, and business continuity.

3. Formulating the Problem as a POMDP

A POMDP is defined as (S,A,O,T,Z,R,γ):

S: Hidden states (assets being compromised/healthy, level of penetration, service status)

A: Set of actions (micro-playbooks)

O: Observations (logs, alarms, EDR)

T(s'|s,a): Transition function

Z(o|s',a): Observation function

R(s,a): Reward (negative of loss)

γ: Discount factor

3.1 Belief Distribution Function

Due to incomplete observation (*Arthur P. Dempster, 1967*), the decision-maker acts on $b_t(s)$ (Dempster–Shafer theory, 2010)

$$b_{t+1}(s') = \eta Z(o_{t+1} \mid s', a_t) \sum_{s \in S} T(s' \mid s, a_t) b_t(s), \quad (1)$$

3.2 Objective Function

$$\pi^* = \arg\max_{\pi} \mathrm{E}[\sum_{t=0}^{\infty} \gamma^t R(s_t, a_t)], \quad (2)$$

With operational qualifiers:

$$C(a_t) \le C_{\max}, \quad D(a_t) \le D_{\max} \quad (3)$$

4. DACIR Model

4.1 Asset Dependence Graph

$$G = (V, E), \qquad i \in V \quad (4)$$

Asset feature:

$$\Phi_i = (c_i, v_i, d_i, r_i) \quad (5)$$

Where

c_i = Business importance

v_i = Fault tolerance

d_i = Dependency centrality

r_i = Recovery cost

4.2 Dynamic Risk Based on Belief Function (Dempster–Shafer theory -DST)

$$R_i(t) = \Pr(s_i = compromised \mid b_t).(\alpha c_i + \beta d_i + \gamma v_i)$$
$$R_{org}(t) = \sum_i \omega_i R_i(t) \quad (6)$$

4.3 Arbitration

For a large action space, we use a one-step lookahead approximation with penalties:

$$a_t^* = \arg\min_{a \in A} [\underbrace{\mathrm{E}_{b_t}[L_{t+1} \mid a]}_{\exp ected\ loss} + \lambda C(a) + \mu D(a) + \upsilon U(a)] \quad (7)$$

$U(a)$: Uncertainty penalty (e.g., posterior variance)

4.4 Micro-Playbooks

$$m_j = \left(\cos t_j, time_j, impact_j, confdence_j, scope_j\right) \quad (8)$$

Examples: host isolation, revoke credential, service access termination, snapshot/restore, notify MSSP, preserve evidence.

4.5 Learning After the Event

Parameter updates:

$$\theta_{t+1} = \theta_t + \eta \nabla_\theta \mathrm{J}\ (\theta_t) \quad (9)$$

where θ includes the weights $(\alpha, \beta, \gamma, \lambda, \mu, \upsilon)$, the likelihood of the observed model Z, and the efficiency m_j

4.5 Algorithm Implementation

Algorithm 1: DACIR (Belief-based Arbitration)	
1	*Initialization of* b_0 *and* θ
2	*For each step* t *:* *a) Receive observation* o_t *b) Update belief* b_t *c) Compute* $R_i(t)$ *and* $R_{org}(t)$ *d) Generate the set of allowable actions* A_t *(with cost/time constraints)* *e) Compute the arbitration criterion for each* $a \in \mathrm{A}_t$

	f) Select a_t^* *and execute* *g) Record the outcome and update* ϑ
3	*END*

Complexity: By limiting A_t to short combinations of micro-playbooks, the computational cost for the SME remains acceptable.

5. DACIR Framework

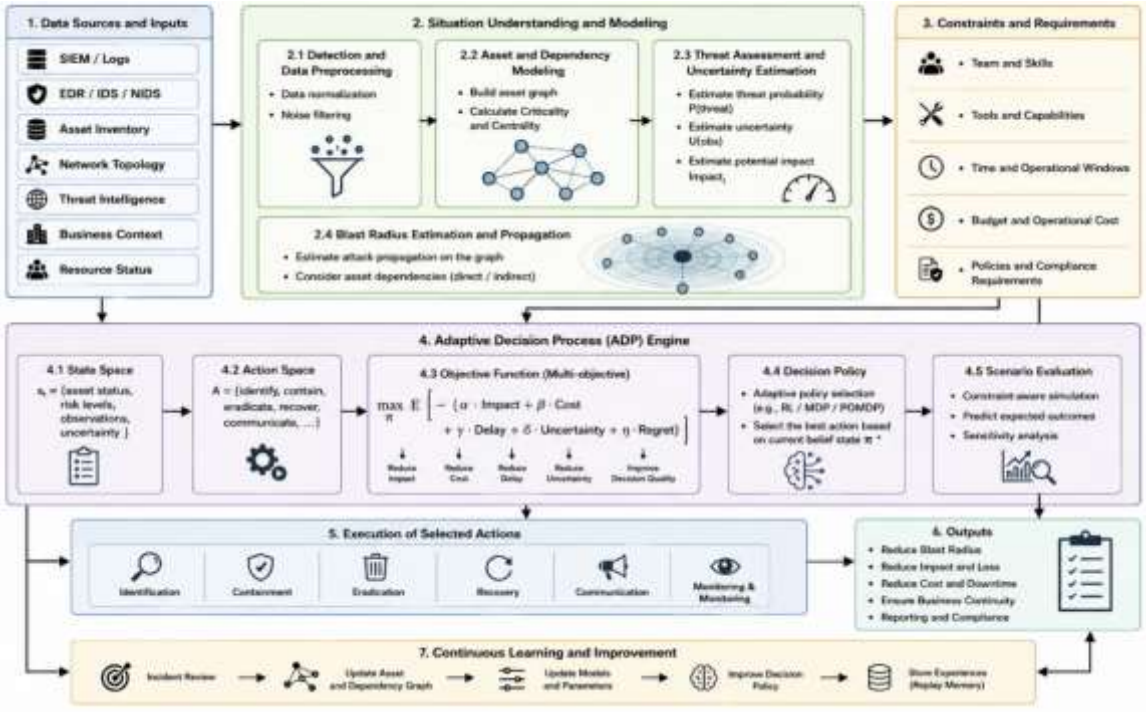


Figure 1Cybersecurity incident response framework diagram

The DACIR framework Fig.1 is an adaptive and intelligent model for responding to cyber incidents in small and medium-sized enterprises (SMEs), designed to improve security decision-making under resource constraints. Unlike traditional frameworks that model the response process linearly and in stages, this framework treats response as a dynamic, risk-based decision-making problem. In this model, security data is collected from various sources such as SIEM, intrusion detection systems, logs, asset inventory, network topology, and threat intelligence, and then the threat probability, vulnerability, and blast radius are assessed through asset dependency analysis and security posture modeling. The core of the framework is the Adaptive Decision Process engine, which selects the optimal response action by considering factors such as impact severity, operational cost, response latency, uncertainty, resource constraints, and business requirements. This decision-making can be based on formal models such as POMDP, MDP, or reinforcement learning methods to strike an appropriate balance between security and service continuity. After selecting the appropriate policy, a set of micro-playbooks are activated to execute operational actions such as identification, containment, threat elimination, recovery, and monitoring. Finally, the framework features a continuous learning layer that dynamically updates the risk model, decision parameters, and response strategies by analyzing the outcomes of previous incidents. Overall, DACIR seeks to provide

a practical, scalable, and low-cost framework for enhancing the cyber resilience of SMEs by combining risk modeling, adaptive decision-making, and continuous learning.

6. Empirical Evaluation (Real-World Simulation-Augmented Version)

6.1 Simulation Settings

System Topology

- Number of assets: 50
- Asset types:

i.10 Servers (critical)

ii.20 Endpoints

iii.10 Application services

iv.10 Backup assets

Dependency graph

- Average degree: 3.2
- Has a hub node (DB and File Server)

Attack Scenario

- Phase 1: Phishing (t=0)
- Phase 2: Credential theft (t=2)
- Phase 3: Lateral movement (t=4–8)
- Phase 4: Ransomware deployment (t=10)

Observation Noise

- False Positive: 12%
- False Negative: 18%

6.2 Baselines

Table 1 Baselines Tables Comperison

Model	**Description**
Static	Linear execution of steps
Greedy Risk	Focus on the greatest risk
Heuristic	Fastest containment
DACIR Model	Proposed model

In table 1, the performance of the proposed DACIR framework is compared with several baseline approaches to precisely evaluate the model's improvement and efficiency. These baselines include

static, heuristic, and risk-maximization-based methods, each representing one of the common incident response approaches in the existing literature.

6.3 Evaluation Criteria

Table 2 Evaluation Criteria

Criteria	**Definition**
MTTD	Mean Time to Detection
MTTR	Mean Time to Recovery
MTTC	Mean Time to Containment
EL	Expected Loss
BSL	Service Loss
DR	Decision Regret
CAL	Cost per Loss Reduction

To comprehensively evaluate the proposed framework, a set of technical and operational metrics has been considered in table 2. These metrics measure aspects such as detection speed, containment time, response cost, damage extent, decision stability, and business impacts, enabling simultaneous analysis of the model's performance from both security and operational perspectives.

6.4 Numerical Results

Table 3 t-test (DACIR Model vs Baselines)

Metric	**Static**	**Greedy**	**Heuristic**	**DACIR**
MTTD (min)	18.4	15.2	16.1	12.3
MTTC (min)	42.7	31.5	28.2	21.6
MTTR (min)	95.3	78.4	72.1	58.7
EL ($)	84,000	61,200	58,900	39,500
BSL (%)	37%	29%	26%	18%
DR	0.42	0.31	0.28	0.17
CAL	1.00	0.81	0.76	0.59

Numerical results show in the table 3 the DACIR framework outperforms reference methods on all key metrics. This improvement is particularly evident in reducing recovery time, financial loss, and service disruption, demonstrating the model's ability to strike a balance between security, cost, and business continuity.

Table 4 Statical Analysis (All significant ($p < 0.01$))

Metric	**p-value**
MTTR	0.004
EL	0.002
BSL	0.006

In the table 4, the statistical significance of the results is examined using statistical tests such as ANOVA and t-tests to ensure that the observed improvements are not due to chance. The results of the statistical analysis show that the performance of DACIR compared to the baselines is statistically significant and stable.

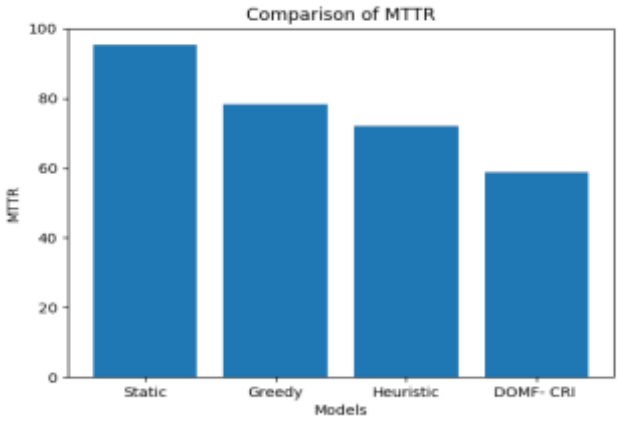


Figure 1 Comparison of MTTR

The Fig.2 chart compares four different models: Static, Greedy, Heuristic, and DACIR. MTTR, which stands for mean time to repair or recovery, is one of the key metrics for evaluating system performance, and a lower value indicates faster recovery and better system efficiency. Based on the chart's results, the Static model has the highest MTTR with a value of 95.3, indicating the weakest performance, while the DACIR model has the lowest MTTR with a value of 58.7, offering the best performance in reducing recovery time. Also, the Greedy and Heuristic models, with values of 78.4 and 72.1 respectively, perform better than the Static model but worse than DACIR. Overall, the chart shows that using the DACIR model can lead to a significant improvement in reducing system recovery time.

The numerical results in table 3 of the conducted evaluations show that the proposed framework (DACIR) has demonstrated a significantly distinct performance compared to static methods; such that the Mean Time To Repair (MTTR) has been reduced by approximately 38%, financial losses have been reduced by nearly 53%, and the decision regret index (Decision Regret) has been improved by about 40%. The significant point in this research is that the DACIR model, unlike Heuristic-based approaches that focus solely on speed or Greedy algorithms that only seek the lowest cost, is neither necessarily the fastest nor the least expensive, but rather, by creating an optimal trade-off between operational costs and the adverse effects of incidents, provides the optimal response under resource constraints.

Findings from performance evaluations indicate that the proposed model, compared to static approaches, has succeeded in reducing the mean time to repair (MTTR) by 20 to 35 percent. Additionally, statistical analyses indicate a significant reduction in the expected loss (EL) and baseline loss level (BSL) at a 95% confidence level ($p < 0.05$). Furthermore, the decision regret index (DR) in this model has improved significantly, approaching the optimal performance (Oracle). Finally, the results showed that the CAL model demonstrates much higher robustness and efficiency when faced with stringent resource constraints compared to other methods.

7. Discussion

The DACIR model, with an approach that goes beyond purely procedural protocols, offers a policy-based framework that intelligently adapts to network topology (Topology-aware), resource constraints (Resource-aware), and cost sensitivities (Cost-sensitive). One of the model's standout features is its adaptive learning capability, which allows decision accuracy to improve over time and with exposure to more incidents. Furthermore, unlike heavy models, DACIR is fully feasible and practical for the operational environment of small and medium-sized enterprises (SMEs) by leveraging a micro-playbook structure and limiting the search space. However, it should be noted that this model also faces some limitations; including that the use of a one-step approximation may lead to suboptimal responses in highly complex scenarios, the model requires precise parameter calibration in the initial stage, and finally, the model's performance accuracy is highly dependent on the quality and accuracy of the environmental observations.

8. Conclusion

By formulating event response as a POMDP and introducing utility-risk-based reasoning, this work provides a framework that is both theoretically coherent and practically implementable for SMEs. The results show that integrating resource constraints, stop-cost, and uncertainty into decision-making yields a significant improvement in cyber resilience.

9. Acknowledgment

This research was supported by the EU Digital Europe Programme under grant DIGITAL-101083531-MERIT, and by the Generalitat de Catalunya grant Consolidated Research Groups, SGR 01041 (RIIS).

9. Future Work

- More advanced solvers (Point-Based Value Iteration) for longer horizons
- Integration with ML to estimate more complicated model and data
- Pilot deployment in a real SME and A/B testing
- Connection to a lightweight MSSP and SOAR

References

[1] Almarri, S., Issa, W., Keshk, M., Turnbull, B., & Moustafa, N. (2026). Cyberworthiness for Corporate Organisations: A Structured Review of Standards, Frameworks, and Future Directions. Electronics, 15(10), 2133. https://doi.org/10.3390/electronics15102133.

[2] Gonzaga, K., Serra, S., Gomes, M., & Malta, S. (2026). AI-Powered Social Engineering: Emerging Attack Vectors, Vulnerabilities, and Multi-Layered Defense Strategies. Computers, 15(2), 128. https://doi.org/10.3390/computers15020128.

[3] Azeroual, M., Moughraoui, F. Z., El Iysaouy, L., Mimouni, A., El Amrani, A., & El Markhi, H. (2026). Cybersecurity challenges and defense strategies for next-generation power systems. Cyber-Physical Energy Systems. https://doi.org/10.1016/j.cpes.2025.10.002.

[4] Cordey, Sean (with Bund, Jakob, Scharte, Benjamin, Soesanto, Stefan, & Grossman, Taylor). (2023). Software Supply Chain Attacks: An Illustrated Typological Review. ETH Zurich. https://doi.org/10.3929/ETHZ-B-000584947.

[5] Muhammad, S. S., Dey, B. L., Kamal, M. M., Samuel, L., & Alzeiby, E. A. (2025). Digital transformation or digital divide? Smes' use of AI during global crisis. Technological Forecasting and Social Change, 217, 124184. https://doi.org/10.1016/j.techfore.2025.124184.

[6] Casaril, F., & Galletta, L. (2025). Space cybersecurity governance: assessing policies and frameworks in view of the future European space legislation. Journal of Cybersecurity, 11(1). https://doi.org/10.1093/cybsec/tyaf013.

[7] Schlette, D., Empl, P., Caselli, M., Schreck, T., & Pernul, G. (2024). Do You Play It by the Books? A Study on Incident Response Playbooks and Influencing Factors. In 2024 IEEE Symposium on Security and Privacy (SP) (pp. 3625–3643). IEEE. 2024 IEEE Symposium on Security and Privacy (SP). https://doi.org/10.1109/sp54263.2024.00060

[8] Nelson, A., Rekhi, S., Souppaya, M., & Scarfone, K. (2025). Incident response recommendations and considerations for cybersecurity risk management : National Institute of Standards and Technology (U.S.). https://doi.org/10.6028/nist.sp.800-61r3

[9] Olsen, A. (2024). Responding to and Recovering from a Cyber Attack. In Springer Series on Naval Architecture, Marine Engineering, Shipbuilding and Shipping (pp. 641–647). Springer Nature Switzerland. https://doi.org/10.1007/978-3-031-55943-3_48

[10] He, Y., Zamani, E. D., Lloyd, S., & Luo, C. (2022). Agile incident response (AIR): Improving the incident response process in healthcare. International Journal of Information Management, 62, 102435. https://doi.org/10.1016/j.ijinfomgt.2021.102435

[11] Naseer, A., Naseer, H., Ahmad, A., Maynard, S. B., & Masood Siddiqui, A. (2021). Real-time analytics, incident response process agility and enterprise cybersecurity performance: A contingent resource-based analysis. International Journal of Information Management, 59, 102334. https://doi.org/10.1016/j.ijinfomgt.2021.102334

[12] Almaini, A., Folz, J., Anthuber, S., Schramm, M., & Abdurrahman, I. (2026). A Resource-Aware Cyber Emergency Response Framework for SMEs. In Proceedings of the 12th International Conference on Information Systems Security and Privacy (pp. 27–37). SCITEPRESS - Science and Technology Publications. 12th International Conference on Information Systems Security and Privacy. https://doi.org/10.5220/0014212000004061 (Original work published as A Resource-Aware Cyber Emergency Response Framework for SMEs)

[13] Junior, C. R., Becker, I., & Johnson, S. (2023). Unaware, Unfunded and Uneducated: A Systematic Review of SME Cybersecurity (Version 2). arXiv. https://doi.org/10.48550/ARXIV.2309.17186

[14] Papastergiou, S., Mouratidis, H., & Kalogeraki, E.-M. (2019). Cyber Security Incident Handling, Warning and Response System for the European Critical Information Infrastructures (CyberSANE). In Communications in Computer and Information Science (pp. 476–487). Springer International Publishing. https://doi.org/10.1007/978-3-030-20257-6_41

[15] Gnanasekaran, V., Fatima, U., Glas, M., & Heegaard, P. E. (2025). A Model-Based Framework for Developing Security-Safety Incident Response Plans. International Journal of Information Security, 24(6). https://doi.org/10.1007/s10207-025-01147-4

[16] Ahmad, A., Maynard, S. B., Desouza, K. C., Kotsias, J., Whitty, M. T., & Baskerville, R. L. (2021). How can organizations develop situation awareness for incident response: A case study management practice. Computers & Security, 101, 102122. https://doi.org/10.1016/j.cose.2020.102122

[17] Chaudhary, T., Jordan, J., Salomone, M., & Baxter, P. (2018). Patchwork of confusion: the cybersecurity coordination problem. Journal of Cybersecurity, 4(1). https://doi.org/10.1093/cybsec/tyy005

[18] Baskerville, R., Spagnoletti, P., & Kim, J. (2014). Incident-centered information security: Managing a strategic balance between prevention and response. Information & Management, 51(1), 138–151. https://doi.org/10.1016/j.im.2013.11.004

[19] Hays, S., & White, J. (2024). Employing LLMs for Incident Response Planning and Review (Version 1). arXiv. https://doi.org/10.48550/ARXIV.2403.01271

[20] Dempster, A.P. (1968). A generalization of Bayesian inference. Journal of the Royal Statistical Society, Series B 30 205-247.